SIMATS ENGINEERING

SIMATS
Saveetha Institute of Medical And Technical Sciences
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

ASSESSMENT TOOL II- ASSIGNMENT

COURSE CODE: ITA14 **COURSE NAME: Ethical Hacking**

COURSE OUTCOME COVERED

CO1: Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

ASSIGNMENTS QUESTIONS

1. A company hires you to test its network but gives you only a one-line email authorization with no defined scope. Halfway through testing, you discover a critical vulnerability in a system that wasn't mentioned in the email. Do you exploit it to prove impact? Justify your answer using ethical hacking principles.
2. You are conducting a penetration test and discover that the client's production database contains real customer financial data. Your test plan calls for exploiting a SQL injection vulnerability. How do you proceed without causing harm, and what precautions should have been taken before the engagement began?
3. During a black-box penetration test, you accidentally trigger a denial-of-service condition on a live production server, causing an outage. Walk through what you should have done to prevent this and what your responsibility is now.
4. A client asks you to test their systems but insists you not inform their IT department, wanting to test the team's real-world detection capability. What ethical and practical risks does this create, and how would you structure the engagement to protect yourself?
5. You're asked to perform a "red team" exercise versus a "vulnerability assessment." Using a real-world scenario of a bank wanting to test physical and digital security, explain how your approach, ethics, and rules of engagement would differ between the two.

Code of Conduct:

I _____ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Rubrics

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Problem Context	20	Clearly understands the problem and accurately identifies all data-handling requirements and operations	Good understanding with minor gaps	Basic understanding; some requirements unclear	Poor understanding or misinterpretation of the problem
Application of Concepts	30	Accurately applies appropriate data structures and algorithms to solve complex problems	Applies relevant concepts correctly with minor errors	Applies basic concepts with limited accuracy	Fails to apply appropriate concepts
Problem-Solving Approach	20	Logical, well-structured, and efficient approach	Mostly logical approach with minor gaps	Basic approach with some inconsistencies	Illogical or unclear approach
Accuracy of Solution	20	Completely correct code, output and complexity analysis with proper justification	Mostly correct with minor errors	Partially correct solution	Incorrect or incomplete solution
Clarity	10	Clear, well-organized, and properly explained solution	Understandable with minor clarity issues	Limited clarity and explanation	Poorly presented and difficult to understand

SIMATS

CO1 - ASSESSMENT - II

NAME : V THANISHA
REG NO : 196526016O
COURSE : ETHICAL HACKING
CODE CODE : ITA1H06
DEPT : CSC (CYBER)

Question : -01

Exploiting A vulnerability without clearly Defined Scope

→ As an ethical hacker, I would not Exploit the critical vulnerability immediately because the company has provided only a one-line email authorization without clearly defining the testing scope.

* Even though, I discovered a serious vulnerability exploiting a system that is not included in the approved scope could cause unexpected damage and created legal problems.

The main ethical Hacking principles involved are :-

Authorized :-

Obtain Explict permission before testing Systems.

Defined Scope :-

Test only the systems and activities approved by the clients.

Non-maleficence :-

Avoid causing harm to system data or users.

Confidentiality :-

Protect all information discovered during the testing.

* firstly, I would document the vulnerability, of including the affected systems its potential impact, and evidence collected without causing Harm.

* then I would inform the client or authorized contact about the discovery and request written permission to test that particular systems.

Conclusion :-

* A critical vulnerabilities does not give an ethical hacker unlimited permission to exploit it. written authorization and clearly defined scope must be obtained before proceeding.

Question :-02

SQL injection in a production database of to containing financial Data.

During a penetration test, discovering real customer financial data in production database require extreme care. Exploiting an SQL injection vulnerability without proper precautions could Expose Confidential information, modify records or disrupt business operations.

I would follow these precautions.

* Avoid retreving, modifying, deleting or copying
* Use harmless test queries or controlled test inputs to confirm the vulnerability.
* Obtain approval for the exact testing method and affected database.
* Establish backups, recovery procedures, monitoring and an emergency stop mechanism.

access to authorised personal and protect all evidence.

Cautions before the engagements :-

Sign a written penetration-testing agreement.

Define the scope, objectives and permitted testing techniques.

Identity sensitive data and system that must not be accessed.

Established incident-response procedures and a Emergency contacts.

I would immediately pause any intrusive testing and inform the clients authorized security contact. Instead of accessing real customers records, I would use a safe test Environment, a staging database or synthetic data wherever possible.

Conclusion :-

The goal of penetration testing is to improve security not to compromise customer priority. The vulnerability should be verified using the least of intrusive method pomible, with proper authorized and safeguards.

Question :- 03

Accidental Denial-of-a Service on a live of production Server.

During a black-box penetration test, accidentally triggering a denial-of-Service (DOS) condition on a live production Server can interrupt business operation and Effect the customers.

Steps that should have been taken to prevent the incident.

* Review the rules of engagement and potentity prohibited high-impact tests.
* Obtain explicts approvals before conducting stress load or denial-of-service-testing.

* When a use a staging environment or isolated
whenever possible.
* Apply conservative testing limits, monitor server performance and establish stop conditions.
* Ensure that recovery and backup procedures.

Responsibilities after the incident :-

* Immediately stop the test activity that caused the outage.
* Notify the clients designated emergency contact and incident-response team.
* Cooperate with authorized personnel to restore the service safely.
* Preserve relevant logs and document the timeline action taken and observed affects.

Conclusion :-

Ethical hacker must prioritize availability to minimize harm and respond honesty to incidents. Responsible reporting and immediate action are to essential for restoring trust and preventing similar failures.

Question :- 04

Testing systems without informing the IT department.

A client may request a lower security test to evaluate whether its IT department can detect real-world attacks. But testing without informing the IT team creates ethical, operational.

For example :-

A bank may want to test wheather its security team detects suspicious login attempts or unauthorized access attempts. If the

genuine attack.

ical and practical risks :-

Legal risks :- The test may Exceed the clients authority or violate applicable laws.

Operational risks :- Testing may disrupt important services or affect Customers.

Misunderstanding :- Security staff may mistake the test for a real Criminal attack.

How I would Structure the Engagement

* Obtain, written authorization from a appropriate senior authority who has the power to approve the Exercises.
* Define the objectives, Scope, permitted techniques, duration and prohibited activities.
* Use a designated controller or trusted coordinator who can intervence if the Exercise caused by them.

Conclusion :-

A convert test can Evaluate real - world detection capabilities but secrecy must never replace authorization clear rules of engagement and emergency controls protect both the Organization and the ethical hacker.

Question :- 05

Red team Exercise Vs Vulnerability Assessment in a bank

A ored team exercise and vulnerability assessment are both Security - testing methods, but they have different objectives and approaches. A vulnerabilities assessment identities security weakness whereas a red

team Exercise Evaluates wheather an Organ...
to .

Vulnerability assessment :-

The primary objective is to identify and a document weakness in the bank's systems.

Approach :-

* Scan approved servers, application and network devices for known vulnerabilities.
* check outdated software, misconfiguration, weak passwords and missing security patches.

Ethical considerations :-

* Obtain written authorization.
* Avoid disrupting banking services or accessing a unecessary customer data.
* Report all findings accurately.

Red team Exercise.

The primary objective is to simulate realistic adversial behaviour and evaluate the banks over all security defenses including detection and incident response.

Approach :-

* Define a realistic objective, such a determining whether an attacker could reach a protected to internal system.
* Simulate approved social - engineering or physical security Scenarios.

al Connideration :-

* Obtain Exploit Expict authorzation for digital , physical and social - Engineering activities .

Conclusion :-

A vulnerability assessment helps the bank discover and fix weakness while a red team Exercise and technology defend against realistic attack .